



Sky: Laniakea NFAT

Security Review

Cantina Managed review by:
M4rio.eth, Lead Security Researcher
Xmxanuel, Lead Security Researcher

March 19, 2026

Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
3	Findings	4
3.1	Informational	4
3.1.1	<code>subscribe()</code> accepts non-members even though <code>issue()</code> later requires identity-network membership	4
3.1.2	Retroactive <code>identityNetwork</code> changes can lock existing NFAT holders	4
3.1.3	<code>_update</code> doesn't validate the <code>identityNetwork</code> membership of the transfer initiator	5

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

Sky Protocol is a decentralised protocol developed around the USDS stablecoin.

From Mar 11th to Mar 13th the Cantina team conducted a review of [nfat](#) on commit hash [b9eaaec8](#). The team identified a total of **3** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	3	1	2
Total	3	1	2

The Cantina Managed team reviewed Sky's [nfat](#) holistically on commit hash [530a5e32](#) and concluded that all findings were addressed and no new vulnerabilities were identified.

3 Findings

3.1 Informational

3.1.1 `subscribe()` accepts non-members even though `issue()` later requires identity-network membership

Severity: Informational

Context: `src/NFATFacility.sol#L174-L180`, `src/NFATFacility.sol#L190-L196`, `src/NFATFacility.sol#L230-L236`

Description: `subscribe()` is permissionless and records deposits for any caller, even when an `identityNetwork` is configured and the caller is not a member.

```
function subscribe(uint256 amount, bytes calldata data) external notStopped {
    if (amount > 0) {
        gem.transferFrom(msg.sender, address(this), amount);
        deposits[msg.sender] += amount;
    }
    emit Subscribe(msg.sender, amount, data);
}

function _update(address to, uint256 tokenId, address auth_) internal override returns
↳ (address) {
    require(
        address(identityNetwork) == address(0) || identityNetwork.isMember(to),
        "NFATFacility/not-member"
    );
    return super._update(to, tokenId, auth_);
}
```

When the operator later calls `issue(to, tokenId, amount)`, the mint path goes through `_mint()` and then `_update()`, which reverts if `to` is not in the identity network. This means a user can successfully subscribe, deposit funds, and appear queued for issuance, while still being unable to receive an NFAT when the operator tries to issue one.

The user can still withdraw the deposit at any time!

Recommendation: Consider adding the same identity-network membership check in `subscribe()` when `identityNetwork` is configured, so users who are currently ineligible to receive an NFAT cannot enter the queue in the first place.

Another fix is to clearly state in the `subscribe()` comments that subscribing does not guarantee the user is currently eligible to receive an NFAT, and that `issue()` can still revert later if the subscriber is not in the identity network.

Sky: Fixed in commit [530a5e32](#).

Cantina Managed: Fix verified.

3.1.2 Retroactive `identityNetwork` changes can lock existing NFAT holders

Severity: Informational

Context: `NFATFacility.sol#L139`

Description: Changing the `identityNetwork` applies retroactively to all existing NFATs. If a previously unrestricted facility (identity network set to `address(0)`) is updated to a restricted one, existing NFAT holders who are not members of the new network will be unable to `collect`, receive transfers, or be issued new NFATs via `_update`.

This is especially relevant in the transition from no identity network to a restricted one, as holders had no prior indication that membership would be required.

Recommendation: This is an accepted trade-off given that only governance can change it and the `rescueCollectable` `rescue` functions exist as emergency recovery paths for stuck funds.

Governance should ensure that identity network changes are coordinated with existing holders .

Sky: Acknowledged.

Cantina Managed: Acknowledged.

3.1.3 `_update` doesn't validate the `identityNetwork` membership of the transfer initiator

Severity: Informational

Context: [NFATFacility.sol#L230](#)

Description: The `_update` override only checks the `to` param of the transfer `identityNetwork.isMember(to)`. A non-member with ERC-721 approval or operator status can still initiate transfers on behalf of a member. If regulatory or legal requirements demand that only members interact with the facility's NFATs, the current check is insufficient.

Recommendation: If legal/compliance reasons require that the transfer initiator must also be a member, add an `identityNetwork.isMember(msg.sender)` check. Otherwise, document the current behavior.

Sky: Acknowledged.

Cantina Managed: Acknowledged.